

# **Design Basis for AI Governance in Critical Infrastructure**

## **A Design Basis for a Governance Process**

### **What It Is, What It Reveals, and What It Requires**

*An Overview of the Eclectic Technologies AI Governance Series*

Version 0.1 — DRAFT for Internal Review

June 2026

Tim Roxey

Eclectic Technologies

*Intended Audience: Asset Owner/Operators, ICS Vendors and Suppliers,  
Regulatory Staff and Standards Community Reviewers*

## **1 What a Design Basis Document Does**

The term design basis comes from nuclear engineering, where it describes the envelope of conditions — accidents, failures, external events, and adversarial threats — that a facility's safety systems are designed and built to withstand. A design basis document does not specify how to build a system. It specifies what the system must survive, at what consequence level, before any specification of how it begins. That ordering matters. Engineering that proceeds without an established design basis is engineering that optimizes against the wrong question.

The concept transfers directly to artificial intelligence governance in industrial control systems. Importantly, this series applies the design basis concept to a governance process rather than a physical system — establishing what the governance framework must prevent, at what consequence level, before any specification of how that governance is implemented begins. The discipline of pre-specification that makes design basis documents valuable in engineering contexts applies equally here: governance that proceeds without an established design basis is governance that optimizes against the wrong question. A design basis for AI governance in critical infrastructure answers three questions before deployment decisions are made: What functions is the AI system performing or advising on? What are the consequences if the AI system fails through error, manipulation, or behavioral excess? And what is the tolerable risk level given those consequences? Once those questions are answered, the design basis document becomes the instrument against which every subsequent governance decision — procurement standards, testing requirements, operator qualification, incident response — is evaluated for adequacy.

This is not a compliance checklist. A design basis document is a pre-regulatory instrument. It reflects the engineering and governance judgments an organization makes about what it is protecting before any regulator has specified what protection is required. For critical infrastructure operators deploying AI today — in an environment where sector regulators have not yet published AI-specific requirements — the design basis is the governance foundation that makes everything else coherent. It is also the document that demonstrates, if scrutiny arrives, that the organization understood what it was doing and made informed decisions about risk.

## **2 The Gap This Series Is Designed to Fill**

Industrial control system security has mature frameworks. IEC 62443 addresses the security of industrial automation and control systems comprehensively, organizing requirements around Security Levels that reflect the capability of the threat actor the system is designed to resist. NERC CIP standards govern cybersecurity for the bulk electric system with enforceable reliability requirements. NRC regulations govern digital instrumentation and control systems in

nuclear facilities with quality assurance requirements that trace their lineage to the 1970s. These are serious, battle-tested frameworks.

None of them were written for generative AI.

The gap is not incidental. IEC 62443 Security Levels classify threats by attacker capability — a high Security Level means the system can resist a sophisticated, well-resourced adversary. That is the right axis for governing cybersecurity. It is the wrong axis for governing AI. A generative AI system does not fail because an attacker exceeded the system's designed resistance level. It fails because its outputs are non-deterministic — the same input can produce different outputs, and the space of possible responses cannot be exhaustively enumerated. There will always be conditions that were not anticipated during qualification testing. Behavioral envelope exceedance, hallucination, automation complacency, stale-context failure — these are AI failure modes, and they have no home in the threat-actor-capability classification scheme that existing ICS security standards use.

The result is that organizations deploying AI in industrial control environments have two bodies of guidance — AI governance frameworks and ICS security frameworks — that were developed in parallel, address different failure modes, and provide no methodology for their integration. This is the gap the Eclectic Technologies AI governance series is designed to fill. The series does not replace existing frameworks. It builds the bridge between them, providing the analytical methodology and governance instruments that allow AI-specific failure modes to be assessed, classified, and governed within the consequence-level structure that critical infrastructure operations already use.

### **3 The Bright Line: Where the Gap Has Consequences**

The gap between AI governance frameworks and ICS security frameworks is an intellectual problem everywhere and a safety problem at the highest consequence levels. This is where the Bright Line Criteria enter the analysis.

The Bright Line, as defined in FD-BL v0.2 (§4.1–§4.5), is a threshold on individual actions: an action is above the line when its incorrect performance — through error, hallucination, or behavioral exceedance — could produce a consequence at or above the facility's severity threshold. Above the line, AI may analyze, synthesize, and recommend but may not command: every above-line action affecting the controlled process must pass through a human decision-maker who evaluates the recommendation and authorizes or rejects it, enforced architecturally. That human is the Command Broker (§4.5). Placement runs action by action, not application by application, and is distinct from the criticality band that sets assessment rigor (§4.3).

The Bright Line Criteria emerged from sustained engagement with the ICS supplier community — the engineers and security professionals at the organizations that build the control systems

deployed in electric utilities, water treatment facilities, nuclear plants, and other critical infrastructure. These practitioners understood intuitively what the standards frameworks had not yet articulated: that the non-deterministic nature of generative AI creates a category of risk that cannot be managed by the same instruments used to manage deterministic system failures. The Bright Line is the governance response to that recognition.

It is a boundary condition — the line above which an unverifiable component's action may not be taken autonomously, regardless of assessed performance, because the residual uncertainty cannot be discharged by testing (FD-BL §4.5). Whether a component needs the broker at all is the determinism scope carve-out (§4.4): deterministic, formally testable-as-deployed components fall outside it. Below the line, and within scope, deployment decisions are governed by the tiered assessment methodology the series provides.

The risk analysis and use cases underlying this series were developed through sustained engagement with representatives of the ICS supplier community. Companies participating in the ISAGCA Supplier Working Group, facilitated by the author, included ABB, AVEVA, Eaton, Hitachi Energy, Honeywell, Johan Nye (ICS.Guru), Rockwell Automation, Schneider Electric, Schweitzer Engineering Laboratories, Siemens, and Xylem.

## **4 The Command Broker: What the Bright Line Requires of People**

Establishing that a human must stand between AI recommendation and control action is the beginning of the governance requirement, not the end of it. The phrase that has become common in AI deployment discussions — 'there is a human in the loop' — does not answer the governance question. It raises it.

A human in the loop who has not been trained to recognize AI failure modes, who has been conditioned by routine AI-correct performance to treat AI output as authoritative, and who has no documented basis for exercising genuine independent judgment is not a safeguard. The architecture is sound; the function is hollow. This is what the Command Broker Implementation Guide addresses. The Command Broker is not a job title. It is a defined function with specific competency requirements, specific cognitive demands, and specific accountability obligations that flow from the Asset Owner/Operator's duty of care.

The duty of care argument is worth stating plainly for an audience that may not be operating under a regulatory mandate: the obligation to ensure that personnel performing safety-significant functions are qualified to perform them exists independently of whether a regulator has written a rule requiring it. An organization that deploys a generative AI system in a Tier 1 application, knows that the Bright Line requires a Command Broker, and places an unqualified individual in that role has accepted a foreseeable risk without adequate mitigation. Duty of care does not require a regulation. It requires only that a court, an insurer, or a counterparty in litigation find

that a reasonable organization in the same position should have known the risk and should have acted to address it.

## 5 The Design Basis Series: A Map of the Documents

The Eclectic Technologies AI governance series is organized as a parent-child document hierarchy. The parent documents establish the governance model, risk taxonomy, and assessment methodology that all sector-specific documents inherit. The sector-specific application guides apply that methodology to the regulatory, operational, and engineering realities of a specific critical infrastructure sector. Companion documents address the risk landscape, methodological foundations, and implementation guidance that support the full series.

**The ISA Parent Framework V1.2** is the sector-neutral root document. It establishes the tiered assessment methodology, the Bright Line Criteria, the Command Broker architecture requirement, and the governance principles that all child documents inherit. Every sector-specific guide is an application of this framework to a particular regulatory environment; none modifies its core requirements.

**The IEEE V&V Cognitive AI Framework V1.3** extends the parent framework into the domain of formal verification and validation. It addresses the specific challenge of verifying the behavior of non-deterministic AI systems, providing the methodological bridge between the deterministic formal methods used for conventional control system verification and the empirical assessment approaches required for generative AI. It targets adoption through IEEE's Power and Energy Society and the AI Power System Coordinating Committee.

**The Tiered Assessment Framework V2.6 (NERC/BES Variant)** applies the parent framework to the bulk electric system regulatory environment, mapping the three-tier criticality model to NERC CIP-002 High, Medium, and Low Impact BES Cyber System categories. It has been submitted to NERC leadership as the foundation for a potential reliability standard addressing AI deployment in BES operations.

**The Water Sector Application Guide V1.2** is the most fully developed sector child document currently available. It applies the parent framework to drinking water and wastewater operations, with regulatory hooks for EPA CWA and NPDES obligations. It provides worked examples, implementation guidance, and assessment criteria specific to water sector operations and the consequence profiles relevant to public health protection.

**The Hybrid Formal Methods White Paper V16** is the methodological foundation document for the series. It develops the analytical argument for combining deterministic formal verification — applicable to the bounded, deterministic infrastructure layers beneath the AI — with empirical cognitive error assessment for the AI layer itself, where formal methods cannot provide complete assurance.

**Generative AI Risk in Industrial Control Systems V29** is the risk landscape companion to the series, developed through sustained engagement with the ICS supplier community. It provides the risk taxonomy, the sector-by-sector consequence analysis, and the Bright Line Criteria framework that the parent document and sector guides operationalize. The ISA Global Cybersecurity Alliance published a version of this document (as of Version 20) on automation.com; Version 29 and subsequent versions represent the author's continuing independent development of this work.

**The Command Broker Implementation Guide V0.2** is the AOO-facing companion to the series, addressed to the people who own and operate critical infrastructure facilities deploying generative AI. It translates the Bright Line's architectural requirement into operational reality: what the Command Broker function looks and feels like, what qualifications it demands, how to train and credential individuals to perform it, and how to build the tabletop exercise program that keeps those qualifications current.

**Sector child documents for nuclear, defense, and natural gas** are anticipated. The nuclear child document is the most strategically pressing, given the current NRC rulemaking activity. The electric sector design basis series is in active development.

## 6 Three Perspectives on the Same Problem

### 6.1 The Vendor and Supplier View

For ICS vendors and suppliers, the design basis series presents both a specification and a market reality. The specification is this: AI systems deployed above the Bright Line in critical infrastructure applications must be architected so that the AI cannot directly command changes to the controlled process without affirmative human authorization through the Command Broker interface. That is an engineering requirement, and it has implications for product architecture, qualification testing, provenance documentation, and customer-facing deployment guidance.

The market reality is that this requirement will eventually arrive as a regulatory mandate. The pace of AI deployment in critical infrastructure is outrunning the standards process, but the standards process is moving. NERC is aware of the gap. NRC is aware of the gap. ISA and IEEE are actively developing standards. Vendors who build to the Bright Line before it becomes mandatory are not incurring a cost disadvantage; they are building a qualification record and a product architecture that will survive the regulatory transition, and their competitors will scramble to address.

There is also a more immediate commercial argument. AOOs procuring AI-augmented control system components increasingly face insurance requirements, board-level risk inquiries, and regulatory scrutiny that they cannot satisfy with a vendor's assurance that the system has been thoroughly tested. They need provenance documentation — a record of how the AI was trained,

what it was trained on, what its operational domain boundaries are, and how its performance was characterized. Vendors who can provide that documentation, structured against the series' tiered assessment framework, are serving an AOO need that vendors who cannot are leaving unaddressed.

## **6.2 The Asset Owner and Operator View**

For AOOs, the design basis series addresses a problem that sits at the intersection of operational benefit and unknown risk. Generative AI deployed thoughtfully in ICS program management — maintenance scheduling, anomaly pattern recognition, compliance documentation support, operator training — can deliver real operational benefits that translate to measurable risk reduction. The question is not whether to engage with this technology. The question is how to engage with it in a way that captures the benefits without accepting uncharacterized risk.

Tool use exposes AOOs to risks they may not have the people, processes, or technology to address. An organization that deploys GenAI without first asking what functions it is performing, what the consequences of failure are, and whether the people operating it are qualified for the function has accepted unknown risk. Unknown risk is the worst risk management position available, because you cannot manage, transfer, or insure what you have not characterized. This is where the design basis concept earns its keep for AOOs specifically: it forces the characterization before the deployment, not after the incident.

The governance infrastructure required for prudent GenAI deployment is not exotic. It maps directly to the People, Process, and Technology framework that most regulated AOOs already use for cybersecurity program management. The technology layer requires procurement standards, provenance documentation requirements, and Command Broker interface specifications. The process layer requires policy, procedures, and audit mechanisms for how AI recommendations are evaluated, authorized, and logged. The people layer requires the Command Broker qualification program that the Implementation Guide provides. Most AOOs with any regulatory history already have management system machinery for all three. They are not building a new compliance program; they are extending an existing one to cover a new category of tool.

The financial case for doing this without a regulatory mandate is straightforward. An AOO who can demonstrate to an insurer — through documented policy, qualified Command Broker personnel, and auditable procedures — that GenAI deployment is governed at the level the design basis series defines is presenting a materially better risk profile than a peer who cannot. Risk that is characterized, governed, and auditable is insurable. Uncharacterized risk is not, or is insured at a significant premium. The governance investment pays for itself not through compliance avoidance but through risk positioning that has direct financial value.

The duty of care dimension reinforces this argument independently of insurance. An AOO who deploys a GenAI system above the Bright Line, knows that the Command Broker function is

safety-significant, and cannot demonstrate that the individuals performing that function were qualified to do so, has accepted a foreseeable liability exposure. The design basis series — and specifically the Command Broker Implementation Guide — provides the documented governance framework that demonstrates due diligence. That documentation matters if scrutiny arrives, and the probability that scrutiny will eventually arrive for GenAI deployments in critical infrastructure is not low.

### **6.3 The Regulatory and Standards View**

For regulators and standards body participants, the design basis series is a gap-finding instrument that also proposes solutions. The gap it identifies is structural, not incidental: existing ICS security frameworks classify threats by attacker capability, which is the right axis for cybersecurity but the wrong axis for AI governance. AI fails on the axis of cognitive error and behavioral envelope exceedance, and no existing standard provides a methodology for assessing, classifying, or governing those failure modes in consequence-tiered critical infrastructure applications.

The series is not a critique of existing standards. IEC 62443 is a sound framework for what it governs. NERC CIP has produced measurable security improvements in the bulk electric system. NRC digital I&C regulations have maintained an enviable safety record through multiple generations of technology transition. The argument is not that these frameworks failed; it is that they were written before the technology they now need to govern existed, and that the bridge between them and AI-specific governance requirements does not yet exist in enforceable form.

The series proposes to build that bridge through a standards pathway that engages ISA, IEEE, NERC, and NRC in parallel rather than sequentially. The tiered assessment methodology provides a common analytical framework that each standards body can adopt within its own regulatory vocabulary — NERC maps to CIP-002 impact categories, NRC maps to safety significance classification, and EPA maps to consequence tiers for public health protection. The Bright Line Criteria provide the cross-sector prohibition that sits above all of them, applicable wherever AI cognitive failure could produce safety-critical or wide-area reliability consequences, regardless of sector.

The IEC 62443 AI Gap Analysis, a companion document in the series, provides the specific mapping between the series' requirements and the existing IEC 62443 framework, identifying the clauses where AI-specific requirements are absent and proposing normative language for their inclusion. This document is currently in peer review with ISA99 and IEC TC65 WG10 committee members. It represents the most immediate pathway for the series' core requirements to achieve international standards recognition.

## **7 How to Engage With This Work**

The documents described in this overview are available through Eclectic Technologies. They are working documents — they reflect the current state of the author's thinking. They will continue to develop as standards engagement, sector-specific application work, and practitioner feedback produce new analytical material. Readers are encouraged to engage critically.

For practitioners — operators, engineers, compliance staff — the most useful engagement is specific: where does a document's requirement not map to your operational reality, and why? The design basis series is designed to be implementable by a systems integrator and auditable by a third party. If it is not, that is information the series needs.

For standards community members — ISA, IEEE, NERC, NRC, NIST, and IEC participants — the series is structured to support parallel engagement across standards bodies. The ISA Parent Framework and the IEEE V&V document are the primary targets for formal standards adoption. The NERC Tiered Assessment Framework has been submitted to NERC leadership. The 62443 AI Gap Analysis is in active peer review. Engagement through any of these pathways is welcome.

For regulators and policy staff — the series is designed to serve as a technical foundation for rulemaking, not a substitute for the regulatory process. The Bright Line Criteria and tiered assessment methodology are offered as analytical inputs that regulators can adopt, adapt, or reject based on their own assessment of what their statutory authority requires and what the state of the technology warrants.

For vendors and suppliers, the most productive engagement is early. The Command Broker interface specification, the provenance documentation requirements, and the tiered acceptance criteria are all available for review and comment before they become regulatory requirements. Vendors who engage now shape the requirements; vendors who engage after the standards are published comply with them.

Questions, feedback, and engagement inquiries should be directed to Tim Roxey, President, Eclectic Technologies.

## **8 Document Control**

Version 0.1, June 2026. Initial draft for internal review and publication preparation. This document is a companion to the Eclectic Technologies AI Governance Series and does not itself establish normative requirements. It is intended for distribution through LinkedIn, Substack, and related professional channels as an introduction to the series and its documents.

Parent document: ISA Parent Framework for Cognitive Errors in Generative AI Systems Deployed in Industrial Control Environments, V1.2, Eclectic Technologies, April 2026.